

Análisis de Malware



Proyecto: Bootcamp KeepCoding 2026

Ref: KC-2026-M6-002

Autor: Dani Garcia (geoSp)

Fecha: 10 Mayo 2026

Informe de Análisis de Malware – BadRabbit.exe

Bootcamp de Ciberseguridad KeepCoding

Fecha: Mayo 2026

Alumno: Dani García

Módulo: Análisis Malware

Entorno: Laboratorio virtualizado con VirtualBox

Vector de entrada: PDF con JavaScript embebido

1. Resumen ejecutivo

El presente informe recoge el análisis estático y dinámico de la muestra `BadRabbit.exe`, ejecutada en un entorno controlado mediante CAPEv2.

La muestra analizada corresponde a un ejecutable PE32 para sistemas Windows que se presenta aparentemente como un instalador/desinstalador de Adobe Flash Player. Sin embargo, durante el análisis se han identificado múltiples indicadores de comportamiento malicioso, entre ellos:

- Suplantación de software legítimo mediante metadatos de Adobe Flash Player.
- Posibles indicios de ofuscación o código embebido por entropía elevada en secciones del PE.
- Creación de persistencia mediante tarea programada.
- Carga de un fichero con extensión anómala como DLL.
- Inyección de procesos y escritura en memoria de otros procesos.
- Intentos masivos de conexión hacia puertos SMB/NetBIOS.
- Técnicas de evasión, anti-debugging y comprobaciones del entorno.
- Comportamiento asociado a impacto/destrucción de datos.

En conjunto, el comportamiento observado permite clasificar la muestra como malware de alto riesgo, compatible con una familia de tipo ransomware/wiper con capacidades de propagación lateral en redes Windows.

2. Datos generales de la muestra

| Nombre del fichero | `BadRabbit.exe` |

| Tipo de fichero | PE32 executable (console) Intel 80386, for MS Windows |

| Tamaño | 441899 bytes |

| MD5 | `fbbdc39af1139aebba4da004475e8839` |

| SHA1 | `de5c8d858e6e41da715dca1c019df0bfb92d32c0` |

| SHA256 | `630325cac09ac3fab908f903e3b00d0dadd5fdaa0875ed8496fcbb97a558d0da` |

| SHA3-384 |

`af433e4633ca0569362eac3ee889b5348b29852f12064a945a5b4d106b1419d6502c8d9276ac97a0073ff927cbd61757` |

| CRC32 | 5FA1C9A5 |
| TLSH |
T1199412426729EE92D1E1B8F84093E7CC4BB97B090FB991EF9D993485CC79B8319380D5 |
| Ssdeep |
12288:BHNTywFAvN86pLbqWRKHZKfErrZJyZ0yqsG03XR63:vT56NbqWRwZaEr3yt203XR63 |

3. Entorno de análisis

El análisis se ha realizado en un entorno controlado mediante **CAPEv2**, herramienta de sandboxing orientada al análisis dinámico de malware. CAPEv2 permite ejecutar muestras en una máquina virtual aislada y registrar actividad de procesos, memoria, red, sistema de ficheros, registro de Windows y firmas de comportamiento.

El uso de CAPEv2 resulta adecuado para este ejercicio porque permite observar el comportamiento real de la muestra, más allá de la información obtenida mediante análisis estático.

4. Análisis estático

4.1 Tipo de fichero

El fichero analizado es un ejecutable PE32 de consola para Windows, compilado para arquitectura Intel 80386.

La muestra no se presenta como un binario arbitrario, sino que utiliza metadatos e iconografía asociados a Adobe Flash Player, lo que refuerza la hipótesis de suplantación de software legítimo.

4.2 Secciones del PE

Sección	Raw Address	Virtual Address	Raw Size	Virtual Size	Permisos	Entropía
.text	0x00000400	0x00001000	0x00002ed3	0x00003000	Execute / Read	6.58
.rdata	0x00003400	0x00004000	0x0000302a	0x00003200	Read	7.18
.data	0x00006600	0x00008000	0x0000033c	0x00000200	Read / Write	0.18
.rsrc	0x00006800	0x00009000	0x00007088	0x00007200	Read	4.20
.reloc	0x0000da00	0x00011000	0x0000024e	0x00000400	Discardable / Read	3.29

La sección **.text** presenta una entropía de **6.58**, relativamente elevada para una sección de código. La sección **.rdata** alcanza una entropía de **7.18**, lo que puede indicar la presencia de datos comprimidos, cifrados, ofuscados o código embebido.

No se debe afirmar necesariamente que la muestra está empaquetada únicamente por la entropía, pero sí existen indicios compatibles con ofuscación o almacenamiento de contenido embebido.

IMAGE BASE
0x00400000

ENTRY POINT
0x000012c0

MIN OS
5.1

COMPILE TIME
2017-10-22 02:33:58

IMPORT HASH
e3bde9df66f1f9b2b967b868518f2af1

ICON HASH
4c7a653ba8759c65ebb8da8846c6d7f

Version Info

Sections

Name	RAW Addr	Virt Addr	Virt Size	Raw Size	Characteristics	Entropy
.text	0x0000400	0x00001000	0x00002ed3	0x00003000	IMAGE_SCN_CNT_CODE IMAGE_SCN_MEM_EXECUTE IMAGE_SCN_MEM_READ	6.58
.rdata	0x00003400	0x00004000	0x0000302a	0x00003200	IMAGE_SCN_CNT_INITIALIZED_DATA IMAGE_SCN_MEM_READ	7.18
.data	0x00006600	0x00008000	0x0000033c	0x00000200	IMAGE_SCN_CNT_INITIALIZED_DATA IMAGE_SCN_MEM_READ IMAGE_SCN_MEM_WRITE	0.18
.rsrc	0x00006800	0x00009000	0x00007088	0x00007200	IMAGE_SCN_CNT_INITIALIZED_DATA IMAGE_SCN_MEM_READ	4.20
.reloc	0x0000da00	0x00011000	0x0000024e	0x00000400	IMAGE_SCN_CNT_INITIALIZED_DATA IMAGE_SCN_MEM_DISCARDABLE IMAGE_SCN_MEM_READ	3.29

4.3 Version Info y suplantación de Adobe Flash

La información de versión del binario intenta aparentar ser un componente legítimo de Adobe Flash Player:

Campo	Valor
CompanyName	Adobe Systems Incorporated
FileDescription	Adobe® Flash® Player Installer/Uninstaller 27.0 r0
FileVersion	27,0,0,170
InternalName	Adobe® Flash® Player Installer/Uninstaller 27.0
LegalCopyright	Copyright © 1996-2017 Adobe Systems Incorporated
OriginalFilename	FlashUtil.exe
ProductName	Adobe® Flash® Player Installer/Uninstaller
ProductVersion	27,0,0,170

Esta información resulta especialmente relevante porque la muestra se presenta como si fuese un instalador/desinstalador legítimo de Adobe Flash Player. Este comportamiento encaja con la técnica **MITRE ATT&CK T1036 – Masquerading**, ya que el malware intenta camuflarse como software legítimo para reducir la sospecha del usuario o del analista.

Version Info	
CompanyName	Adobe Systems Incorporated
FileDescription	Adobe® Flash® Player Installer/Uninstaller 27.0 r0
FileVersion	27,0,0,170
InternalName	Adobe® Flash® Player Installer/Uninstaller 27.0
LegalCopyright	Copyright © 1996-2017 Adobe Systems Incorporated
LegalTrademarks	Adobe® Flash® Player
OriginalFilename	FlashUtil.exe
ProductName	Adobe® Flash® Player Installer/Uninstaller
ProductVersion	27,0,0,170
Translation	0x0409 0x04b0

4.4 Recursos

Los recursos identificados incluyen varios iconos, un grupo de iconos, información de versión y manifiesto:

Recurso	Tipo	Entropía
RT_ICON	Icono	3.48
RT_ICON	Icono	3.09
RT_ICON	Icono	2.15
RT_ICON	Icono	3.58
RT_ICON	Icono	3.44
RT_GROUP_ICON	Grupo de iconos	2.72
RT_VERSION	Información de versión	3.43
RT_MANIFEST	Manifiesto	4.80

La presencia de iconos y metadatos de Adobe refuerza la hipótesis de suplantación visual y documental del binario.

4.5 Imports relevantes

KERNEL32

Funciones destacadas:

- `CreateProcessW`
- `CreateFileW`
- `ReadFile`
- `WriteFile`
- `GetSystemDirectoryW`
- `GetModuleFileNameW`
- `GetCommandLineW`
- `GetFileSize`
- `HeapAlloc`
- `HeapFree`
- `TerminateProcess`
- `SetUnhandledExceptionFilter`

Estas funciones permiten crear procesos, manipular ficheros, localizar rutas del sistema, leer argumentos de ejecución y manejar errores/excepciones.

USER32

- `wsprintfW`

Utilizada para formateo de cadenas en formato wide-char.

SHELL32

- `CommandLineToArgvW`

Permite procesar argumentos de línea de comandos.

MSVCRT

- `wcsstr`
- `memcpy`
- `malloc`
- `free`

Funciones estándar de manipulación de memoria y cadenas.

Aunque la tabla de imports no es excesivamente grande, el análisis dinámico muestra carga dinámica de funciones y uso de APIs nativas, lo que indica que parte del comportamiento real se resuelve en tiempo de ejecución.

P KERNEL32	
Address	Name
0x404000	ExitProcess
0x404004	GetCommandLine
0x404008	GetFileSize
0x40400c	CreateProcessW
0x404010	HeapAlloc
0x404014	HeapFree
0x404018	GetModuleHandleW
0x40401c	GetProcessHeap
0x404020	WriteFile
0x404024	GetSystemDirectoryW
0x404028	ReadFile
0x40402c	GetModuleFileNameW
0x404030	CreateFileW
0x404034	lstrcatW
0x404038	CloseHandle
0x40403c	UnhandledExceptionFilter
0x404040	GetCurrentProcess
0x404044	TerminateProcess
0x404048	SetUnhandledExceptionFilter
P USER32	
Address	Name
0x404058	wsprintfW
P SHELL32	
Address	Name
0x404050	CommandLineToArgvW
P msvcrt	
Address	Name
0x404060	wcsstr
0x404064	memcpy
0x404068	free
0x40406c	malloc

5. Análisis dinámico en CAPEv2

5.1 Reconocimiento del sistema

Durante la ejecución, CAPEv2 detecta que la muestra consulta información del sistema, incluyendo el hostname del equipo mediante `GetComputerNameW`.

```
ComputerName: DESKTOP-2M7E81F
API: GetComputerNameW
Status: success
```

Este comportamiento se asocia a **Discovery**, ya que permite al malware identificar el equipo infectado y adaptar su ejecución al entorno.

También se observa consulta del idioma/localización del sistema mediante

`GetUserDefaultLCID`, obteniendo como resultado:

```
LanguageName: Spanish (Spain)
SystemDefaultLangID: 0x00000c0a
```

Este comportamiento puede estar relacionado con geofencing, adaptación regional o lógica condicional según el idioma del sistema.

Queries computer hostname								
Time	TID	Caller	API	Arguments	Status	Return	Repeated	
2026-04-29 08:49:51,069	3440	0x7ff7bd381c6 0x7ff753427d8	GetComputerNameW	ComputerName: DESKTOP-2M7E81F	success	0x00000001		
2026-04-29 08:47:58,224	6124	0x05d47f41 0x05d47a01	GetComputerNameW	ComputerName: DESKTOP-2M7E81F	success	0x00000001		

Queries the computer locale (possible geofencing)								
Time	TID	Caller	API	Arguments	Status	Return	Repeated	
2026-04-29 09:03:19,272	32	0x00ea8797 0x00ea89c7	GetUserDefaultLCID	SystemDefaultLangID: 0x00000c0a LanguageName: Spanish (Spain)	success	0x00000c0a	1 time	
2026-04-29 08:48:09,187	6372	0x00ea8797 0x00ea89c7	GetUserDefaultLCID	SystemDefaultLangID: 0x00000c0a LanguageName: Spanish (Spain)	success	0x00000c0a	1 time	
2026-04-29 08:48:09,653	5412	0x004d8f01 0x004d72fc	GetUserDefaultLCID	SystemDefaultLangID: 0x00000c0a LanguageName: Spanish (Spain)	success	0x00000c0a		

5.2 Comprobación de privilegios

La muestra consulta información del token del proceso mediante

`NtQueryInformationToken`, lo que puede utilizarse para determinar si el proceso se ejecuta con privilegios elevados o si dispone de contexto administrativo.

Este comportamiento es relevante porque muchas familias de malware modifican su flujo de ejecución dependiendo de si tienen privilegios suficientes para escribir en rutas del sistema, crear servicios, modificar claves de registro o lanzar procesos como `SYSTEM`.

Queries process token information to check for Administrator privileges or UAC elevation status								
Time	TID	Caller	API	Arguments	Status	Return	Repeated	
2026-04-29 08:49:38,882	6296	0x7ff684661f5d 0x7ff6846615d4	NtQueryInformationToken	TokenInformationClass: 20 TokenInformation: \x01\x00\x00\x00	success	0x00000000		
2026-04-29 08:49:38,882	6296	0x7ff684661f5d 0x7ff6846615d4	NtQueryInformationToken	TokenInformationClass: 18 TokenInformation: \x01\x00\x00\x00	success	0x00000000		
2026-04-29 08:47:56,943	6124	0x00585cad 0x00585d49	NtQueryInformationToken	TokenInformationClass: 18 TokenInformation: \x01\x00\x00\x00	success	0x00000000		

5.3 Técnicas anti-debug y anti-análisis

CAPEv2 detecta el uso de `SetUnhandledExceptionFilter`, una API que puede utilizarse como mecanismo anti-debug o para alterar el flujo normal de excepciones.

```
API: SetUnhandledExceptionFilter
Status: success
```

También se observa carga dinámica de funciones mediante `LdrGetProcedureAddress`, incluyendo funciones de `ntdll.dll` y `apphelp.dll`.

Este tipo de comportamiento puede utilizarse para:

- Resolver APIs en tiempo de ejecución.
- Evitar que todas las funciones aparezcan directamente en la tabla de imports.
- Dificultar el análisis estático.
- Adaptar el comportamiento a la versión o arquitectura del sistema.

SetUnhandledExceptionFilter detected (possible anti-debug)							
Time	TID	Caller	API	Arguments	Status	Return	Repeated
2026-04-29 08:48:12.947	6504	0x7f74178580d 0x7f74178591d	SetUnhandledExceptionFilter	ExceptionFilter: 0x7f7417857b8	success	0x00000001	

5.4 Acceso a configuración regional del sistema

Además de consultar el idioma mediante `GetUserDefaultLCID`, CAPEv2 detecta acceso a claves de registro relacionadas con la configuración regional:

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Control\Nls\CustomLocale\es-ES  
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Control\Nls\ExtendedLocale\es-ES
```

Este comportamiento indica que durante la ejecución se accede a información de localización del sistema. No obstante, al tratarse de un sandbox configurado en español, este acceso también puede formar parte de actividad normal del sistema operativo o de librerías cargadas durante la ejecución.

Por tanto, no se puede afirmar de forma concluyente que exista geofencing. La interpretación más prudente es considerar este punto como un posible uso de información regional en lógica condicional, pendiente de confirmación mediante análisis más profundo del flujo de ejecución.

5.5 Carga anómala de `infpub.dat` como DLL

Uno de los eventos más relevantes del análisis dinámico es la carga del fichero:

```
C:\Windows\infpub.dat
```

CAPEv2 lo marca como:

```
A file with an unusual extension was attempted to be loaded as a DLL.
```

La carga se realiza mediante `LdrLoadDll`, pese a que el fichero tiene extensión `.dat`, lo que no corresponde a una DLL convencional.

Este comportamiento es altamente sospechoso. La muestra parece desplegar o utilizar un componente auxiliar con extensión no estándar, cargándolo posteriormente como módulo ejecutable. Esto puede servir para ocultar funcionalidad maliciosa, evadir análisis superficial o separar el loader inicial del payload principal.

A file with an unusual extension was attempted to be loaded as a DLL.							
Time	TID	Caller	API	Arguments	Status	Return	Repeated
2026-04-29 08:47:57.396	6124	0x00583c6d 0x00583e77	LdrLoadDll	Flags: 0x00000000 FileName: C:\Windows\impub.dat BaseAddress: 0x731d0000	success	0x00000000	

5.6 Persistencia mediante tarea programada

CAPEv2 registra la creación de una tarea programada con el nombre `rhaegal`:

```
schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR  
"C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id  
18001039 && exit"
```

Este comando indica varios puntos importantes:

- Se crea una tarea programada mediante `schtasks`.
- La tarea se ejecuta como `SYSTEM`.
- La ejecución se programa al inicio del sistema (`ONSTART`).
- La tarea lanza `C:\Windows\dispci.exe`.
- El uso de `cmd.exe /C` permite ejecutar el comando y cerrar la shell al finalizar.

Este comportamiento encaja con técnicas de persistencia y ejecución automática al arranque.

Técnicas MITRE asociadas:

- **T1053 – Scheduled Task/Job**
- **T1547 – Boot or Logon Autostart Execution**
- **T1543 – Create or Modify System Process**

Uses Windows utilities for basic functionality	
command:	ic schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR "C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id 18001039 && exit"
command:	ic schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR "C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id 18001039 && exit"
command:	ic schtasks /Create /SC once /TN drogon /RU SYSTEM /TR "C:\Windows\system32\shutdown.exe /h /f /t 11:06:00"
command:	ic schtasks /Create /SC once /TN drogon /RU SYSTEM /TR "C:\Windows\system32\shutdown.exe /h /f /t 11:06:00"
command:	ic wevtutil cl Setup & wevtutil cl System & wevtutil cl Security & wevtutil cl Application & tsutil usn deletejournal /D C:
command:	ic schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR "C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id 18001039 && exit"
command:	ic schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR "C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id 18001039 && exit"
command:	ic schtasks /Create /SC once /TN drogon /RU SYSTEM /TR "C:\Windows\system32\shutdown.exe /h /f /t 11:06:00"
command:	ic schtasks /Create /SC once /TN drogon /RU SYSTEM /TR "C:\Windows\system32\shutdown.exe /h /f /t 11:06:00"

5.7 Inyección de procesos

CAPEv2 detecta varios comportamientos compatibles con inyección de procesos:

- Creación de procesos en estado suspendido.
- Reanudación de hilos en otros procesos.
- Escritura en memoria de otro proceso.

- Uso de procesos como `rundll32.exe`, `svchost.exe` y `taskhostw.exe`.

Ejemplo observado:

```
Creates a process in a suspended state, likely for injection
CommandLine: taskhostw.exe -RegisterDevice -ProtectionStateChanged -
FreeNetworkOnly
CreationFlags: CREATE_SUSPENDED
```

También se observa:

Process rundll32.exe wrote to the memory of another process
API: NtWriteVirtualMemory / NtWow64WriteVirtualMemory64

Este patrón es compatible con técnicas de inyección o process hollowing, donde el malware crea o manipula procesos aparentemente legítimos para ejecutar código malicioso dentro de ellos.

Técnicas MITRE asociadas:

- **T1055 – Process Injection**
- **T1106 – Native API**
- **T1027 – Obfuscated Files or Information**

Time	TID	Caller	API	Arguments	Status	Return	Repeated
2026-04-29 08:49:34,117	5584	0x7fff80926ab6 0x7fff81d3cb54	CreateProcessInternalW	ApplicationName: CommandLine: taskhostw.exe -RegisterDevice -ProtectionStateChanged -FreeNetworkOnly CreationFlags: CREATE_SUSPENDED CREATE_UNICODE_ENVIRONMENT EXTENDED_STARTUPINFO_PRESENT 0x00000400 ProcessId: 1460 ThreadId: 6296 ParentHandle: 0x00000000 ProcessHandle: 0x000000648 ThreadHandle: 0x00000724 StackPivoted: no	success	0x00000001	

[illegible]

5.8 Acceso a carpetas públicas

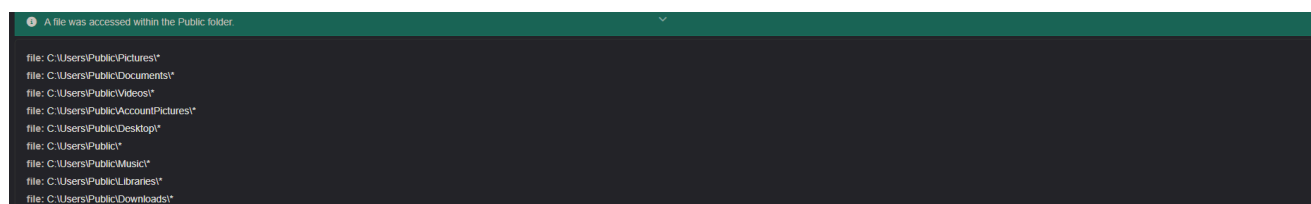
CAPEv2 detecta acceso a múltiples rutas dentro de C:\Users\Public\, incluyendo:

```
C:\Users\Public\Pictures\*
C:\Users\Public\Documents\*
C:\Users\Public\Videos\*
```

```
C:\Users\Public\Desktop\*  
C:\Users\Public\Downloads\*
```

Este comportamiento puede estar relacionado con:

- Enumeración de ficheros.
- Preparación de datos para cifrado o destrucción.
- Búsqueda de ubicaciones comunes con documentos de usuario.
- Abuso de carpetas accesibles sin privilegios elevados.



6. Análisis de red

6.1 Conexiones SMB/NetBIOS

Uno de los comportamientos más claros de la muestra es el intento masivo de conexión a IPs del rango local `192.168.122.0/24` mediante los puertos `445` y `139`.

CAPEv2 registra:

```
Attempts to connect to a dead IP:Port (488 unique times)
```

Ejemplos:

```
192.168.122.0:445  
192.168.122.0:139  
192.168.122.1:445  
192.168.122.1:139  
192.168.122.2:445  
192.168.122.2:139  
...
```

Estos puertos están asociados a SMB y NetBIOS, servicios habituales en entornos Windows para compartición de archivos, recursos de red y comunicación entre equipos. El patrón observado sugiere que la muestra intenta identificar sistemas accesibles dentro de la red local, probablemente como parte de una lógica de propagación lateral o enumeración de recursos compartidos.

6.2 Peticiones HTTP

CAPEv2 también detecta intentos de peticiones HTTP hacia varias IPs:

204.79.197.222:80
52.123.224.133:80
20.190.147.10:80
13.107.3.254:80
79.116.255.72:80
192.168.122.1:80

Estas direcciones se conservan como tráfico observado durante la ejecución, pero no se clasifican directamente como servidores C2. Algunas IPs pueden corresponder a infraestructura legítima, CDN, servicios de Microsoft o tráfico generado por el propio entorno Windows/sandbox.

Por tanto, la conclusión prudente es que la muestra genera actividad HTTP durante la ejecución, pero no se dispone de evidencia suficiente para atribuir estas conexiones a infraestructura maliciosa confirmada.

▲ Performs HTTP requests potentially not found in PCAP							
url: http://150.171.74.254/ url: http://23.40.112.58/ url: http://150.171.27.11/ url: http://13.107.3.254/ url: http://150.171.109.82/ url: http://79.116.255.72/ url: http://192.168.122.1/ url: http://4.207.247.138/ url: http://20.190.147.10/ url: http://2.20.187.19/ url: http://104.83.13.150/ url: http://52.123.224.133/ url: http://204.79.197.254/ url: http://204.79.197.222/							
Time	TID	Caller	API	Arguments	Status	Return	Repeated
2026-04-29 08:48:28.631	5696	0x05d4963d 0x05d4a171	WinHttpGetProxyForUrl	SessionHandle: 0x02de0428 Url: http://192.168.122.1/	failed	0x00000000	
2026-04-29 08:48:43.084	3824	0x05d4963d 0x05d4a171	WinHttpGetProxyForUrl	SessionHandle: 0x02de0d90 Url: http://204.79.197.222/	failed	0x00000000	
2026-04-29 08:48:43.834	6344	0x05d4963d 0x05d4a171	WinHttpGetProxyForUrl	SessionHandle: 0x02de23b8 Url: http://150.171.74.254/	failed	0x00000000	
2026-04-29 08:48:43.865	1888	0x05d4963d 0x05d4a171	WinHttpGetProxyForUrl	SessionHandle: 0x06014358 Url: http://13.107.3.254/	failed	0x00000000	

7. Mapeo MITRE ATT&CK

Táctica	Técnica	Evidencia observada
Discovery	T1033 – System Owner/User Discovery	Consulta de hostname y usuario/sistema
Discovery	T1082 – System Information Discovery	Comprobaciones del entorno
Discovery	T1083 – File and Directory Discovery	Enumeración/acceso a carpetas públicas
Discovery	T1057 – Process Discovery	Enumeración de procesos
Credential Access	T1003 – OS Credential Dumping	Detección CAPE de posible credential dumping
Credential Access	T1539 – Steal Web Session Cookie	Detección CAPE asociada a cookies

Táctica	Técnica	Evidencia observada
Execution	T1059 – Command and Scripting Interpreter	Uso de <code>cmd.exe /C</code>
Execution	T1106 – Native API	Uso de APIs nativas
Execution	T1129 – Shared Modules	Carga de módulo <code>infpub.dat</code>
Persistence	T1053 – Scheduled Task/Job	Tarea programada <code>rhaegal</code>
Persistence	T1547 – Boot or Logon Autostart Execution	Ejecución al arranque mediante <code>ONSTART</code>
Persistence	T1543.003 – Windows Service	Manipulación/creación de servicios detectada por CAPE
Privilege Escalation	T1548 – Abuse Elevation Control Mechanism	Comprobación de privilegios
Defense Evasion	T1036 – Masquerading	Metadatos falsos de Adobe Flash
Defense Evasion	T1027 – Obfuscated Files or Information	Entropía elevada y carga dinámica
Defense Evasion	T1027.002 – Software Packing	Indicadores de entropía/ofuscación
Defense Evasion	T1497 – Virtualization/Sandbox Evasion	Checks de entorno y delay
Defense Evasion	T1562 – Impair Defenses	Detecciones CAPE de evasión
Defense Evasion	T1070 – Indicator Removal	Limpieza de logs/eliminación de ficheros ejecutados
Command and Control	T1071 – Application Layer Protocol	Tráfico HTTP
Command and Control	T1573 – Encrypted Channel	Operaciones criptográficas detectadas
Collection	T1074 – Data Staged	Dropping/staging de ficheros
Impact	T1485 – Data Destruction	Detecciones asociadas a destrucción/borrado

7.1 Técnicas CAPE no validadas manualmente

CAPEv2 incluye también técnicas asociadas a **T1003 – OS Credential Dumping** y **T1539 – Steal Web Session Cookie**. Sin embargo, en la evidencia revisada no se ha localizado todavía el evento concreto, API, fichero, proceso o artefacto que justifique de forma directa estas técnicas.

Por este motivo, se mantienen como detecciones automáticas de CAPEv2 pendientes de validación, y no como comportamiento confirmado manualmente.

8.3 Tarea programada

```
rhaegal
```

8.4 Comando de persistencia

```
schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR  
"C:\Windows\system32\cmd.exe /C Start \"\" \"C:\Windows\dispci.exe\" -id  
18001039 && exit"
```

8.5 Puertos observados

```
139/TCP  
445/TCP  
80/TCP  
443/TCP
```

8.6 Rango interno observado

```
192.168.122.0/24
```

8.7 Muestra representativa de conexiones observadas

```
192.168.122.1:445  
192.168.122.1:139  
192.168.122.10:445  
192.168.122.10:139  
204.79.197.222:80  
52.123.224.133:80  
79.116.255.72:80
```

Las IPs externas no se consideran IOCs maliciosos confirmados sin validación adicional. Se incluyen únicamente como tráfico observado durante la ejecución en CAPEv2.

9. Impacto potencial

El comportamiento observado permite considerar la muestra como una amenaza de impacto alto o crítico para entornos Windows.

Los principales riesgos identificados son:

- Cifrado o destrucción de información.
- Persistencia al arranque del sistema.
- Ejecución con privilegios elevados mediante tarea programada como `SYSTEM`.

- Movimiento lateral o intento de propagación mediante SMB/NetBIOS.
- Inyección de procesos para ocultar ejecución maliciosa.
- Uso de componentes con extensiones no estándar para dificultar la detección.
- Evasión de análisis mediante checks de entorno, idioma, tiempo y anti-debugging.

En una red corporativa, una muestra con este comportamiento podría propagarse rápidamente si existen recursos compartidos accesibles, credenciales reutilizadas o una segmentación de red insuficiente.

10. Mitigación y recomendaciones

10.1 Contención inmediata

- Aislar el equipo afectado de la red.
- Bloquear temporalmente tráfico SMB lateral no esencial.
- Desconectar recursos compartidos expuestos.
- Revisar conexiones salientes HTTP/HTTPS sospechosas.
- Capturar evidencias antes de eliminar ficheros, si el entorno requiere análisis forense.

10.2 Erradicación

- Revisar y eliminar la tarea programada `rhaegal`.
- Comprobar la existencia de:

```
C:\Windows\infpub.dat  
C:\Windows\dispci.exe
```

- Analizar procesos relacionados con `rundll32.exe`, `svchost.exe`, `taskhostw.exe` y cualquier proceso creado en estado suspendido.
- Revisar modificaciones de registro relacionadas con autorun, servicios y persistencia.
- Realizar escaneo completo con solución EDR/antimalware actualizada.

10.3 Recuperación

- Restaurar sistemas desde backups limpios.
- Verificar que los backups no estén cifrados o contaminados.
- Rotar credenciales de usuarios afectados.
- Revisar credenciales administrativas y cuentas de servicio.
- Validar integridad del sistema antes de reconectarlo a red.

10.4 Prevención futura

- Segmentar la red para limitar movimiento lateral.
- Restringir SMB entre estaciones de trabajo.

- Deshabilitar SMBv1 si estuviera habilitado.
- Monitorizar creación de tareas programadas con privilegios `SYSTEM`.
- Aplicar reglas de detección sobre rutas y nombres observados.
- Mantener sistemas Windows actualizados.
- Bloquear ejecución de binarios no autorizados desde rutas temporales o no confiables.
- Implementar políticas de mínimos privilegios.
- Formar a usuarios frente a instaladores falsos y actualizaciones fraudulentas.

11. Limitaciones del análisis

El análisis realizado permite identificar comportamientos relevantes de la muestra, pero presenta varias limitaciones que deben tenerse en cuenta:

- El análisis se basa principalmente en la ejecución dentro de CAPEv2. Algunas rutas de código pueden no haberse activado por condiciones de entorno, temporizadores, fecha, privilegios, conectividad o detección de sandbox.
- La mayoría de conexiones SMB/NetBIOS observadas fallan, por lo que no se puede afirmar que la muestra haya logrado propagarse lateralmente durante esta ejecución. Sí puede afirmarse que intentó conectar con múltiples hosts mediante puertos típicos de compartición Windows.
- Las IPs HTTP observadas no se consideran automáticamente C2. Varias pueden corresponder a infraestructura legítima del sistema operativo, servicios de Microsoft, CDN o tráfico generado por el entorno.
- Algunas técnicas MITRE proceden de firmas automáticas de CAPEv2 y no todas han sido validadas manualmente con artefactos concretos.
- La muestra puede desplegar comportamiento distinto en una red real, con recursos SMB accesibles, credenciales válidas, otros idiomas de sistema o conectividad externa completa.
- No se ha realizado en esta fase reversing manual profundo con desensamblador/debugger, por lo que ciertas hipótesis, como ofuscación interna, lógica condicional o flujo exacto de cifrado/destrucción, quedan pendientes de confirmación.

12. Conclusión

El análisis de `BadRabbit.exe` muestra una amenaza orientada principalmente al impacto operativo sobre sistemas Windows. Lo más relevante no es un único indicador aislado, sino la combinación de varios comportamientos: suplantación de Adobe Flash Player, persistencia al arranque, carga de un componente `.dat` como DLL, manipulación de procesos, escritura en memoria ajena e intentos masivos de conexión hacia servicios SMB/NetBIOS.

La muestra presenta un perfil especialmente peligroso en redes Windows con baja segmentación, recursos compartidos accesibles o controles débiles sobre tareas programadas y ejecución con privilegios. Aunque en el sandbox no se confirma propagación

efectiva ni se validan todos los eventos MITRE de forma manual, el comportamiento observado es suficiente para clasificarla como una amenaza crítica que debe tratarse como incidente grave.

La principal conclusión defensiva es que la detección no debe centrarse solo en el hash de la muestra. También deben monitorizarse comportamientos: creación de tareas `ONSTART` con usuario `SYSTEM`, aparición de ficheros como `infpub.dat` o `dispci.exe` en rutas de Windows, uso anómalo de `rundll32.exe` / `svchost.exe`, conexiones laterales a `445/139` y carga de módulos con extensiones no habituales.

Informe generado por Dani Garcia (geoSp) — Bootcamp KeepCoding 2026 — Módulo Analisis de Malware _Fecha: 10 de Mayo de 2026 Clasificación: Confidencial — Uso académico